

CYBERSECURITY REPORT – OCTOBER 2026

VAPT Tools – Practical Learning Report

Vulnerability Assessment & Penetration Testing

1. Introduction to VAPT

Field	Details
Name	Mohammed Avesh Shaikh
Role	Cybersecurity Analyst
Authorized Target	testasp.vulnweb.com
Email	aveshshaikh05042005@gmail.com

1.1 Definition of Vulnerability Assessment and Penetration Testing

Vulnerability Assessment (VA): A systematic, automated, or semi-automated evaluation designed to identify, quantify, and prioritize security weaknesses across network interfaces, host operating systems, and web application layers. It provides comprehensive visibility into an asset's potential attack surface without attempting active exploitation.

Penetration Testing (PT): A targeted, goal-oriented security assessment that simulates real-world adversary tactics, techniques, and procedures (TTPs). Penetration testing actively validates discovered vulnerabilities by safely attempting exploitation to determine the operational impact and reach of potential unauthorized access.

1.2 Purpose & Scope

This practical evaluation report details the hands-on security assessment conducted exclusively against the authorized public training environment

<http://testasp.vulnweb.com>. The scope encompasses basic network reconnaissance, web server vulnerability auditing, and HTTP request interception.

1.3 Assessment Objectives

- **Network Service Mapping:** Identify active open ports, transport protocols, and exposed services using Nmap stealth and version scans.
 - **Version Fingerprinting:** Detect precise software banner versions and operating system signatures across listening ports.
 - **Web Server Security Auditing:** Perform automated vulnerability checks using Nikto to discover server misconfigurations and dangerous files.
 - **HTTP Traffic Interception:** Intercept, inspect, and analyze client-server HTTP communication headers and parameters using Burp Suite Proxy.
 - **Vulnerability Categorization:** Aggregate and prioritize findings according to risk levels and practical security impact.
 - **Practical Workflow Synthesis:** Document a step-by-step practical VAPT workflow to solidify offensive security methodologies.
-

2. Lab Environment and Authorization

2.1 Target Environment

The primary target evaluated during this assessment is <http://testasp.vulnweb.com>, an active authorized Acunetix testing environment deliberately hosted for security testing and educational research.

2.2 Authorization Statement

All testing activities documented in this report were performed with explicit authorization provided publicly by Acunetix for the vulnweb.com domain family,

specifically targeting `testasp.vulnweb.com`. No unauthorized scanning or exploitation was directed toward third-party systems.

2.4 Ethical and Safety Note

Security assessments must strictly respect defined Rules of Engagement (RoE). Automated tools were configured with rate controls to prevent Denial of Service (DoS) conditions or disruption to shared educational infrastructure.

Lab/Target Access Evidence: Authorized Test Site (<http://testasp.vulnweb.com>)

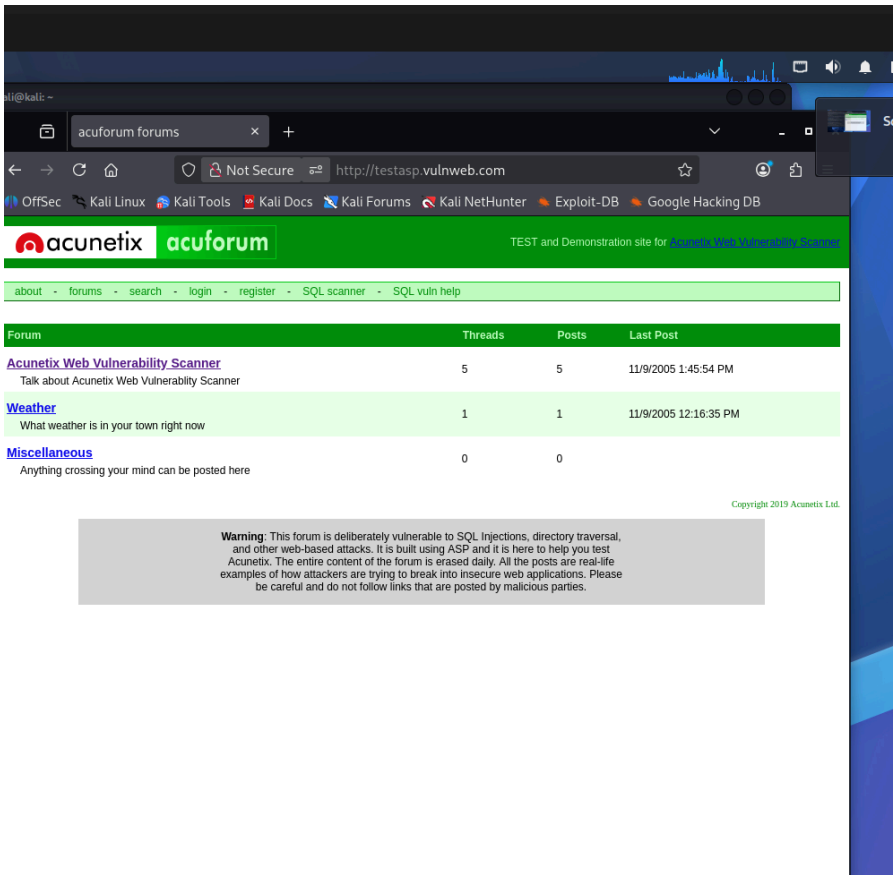


Figure 2.2: Authorized target web application `testasp.vulnweb.com`

2.5 Authorized Target Evidence

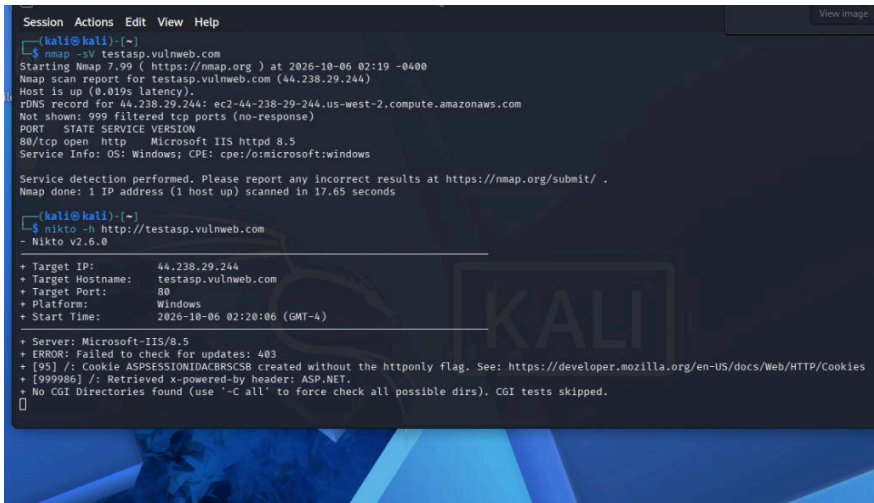


Figure 2.1: Authorized target web application testasp.vulnweb.com

Tool	Purpose	Main Evidence
Nmap	Port, service and basic host detection	Scan outputs
Nikto	Web-server and common web-security checks	Nikto findings
Burp Suite	HTTP request interception and inspection	2–3 captured requests

3. Task 1 – Nmap Network Scanning

3.2 Service and Version Detection

Executed Command:

`nmap -sV testasp.vulnweb.com`

Methodology & Explanation: Version detection interrogates exposed ports using specific service probes to extract banner details and determine exact software versions running on listening ports.

Scan Output:

Figure: Nmap Service and Version Detection (-sV) Result on testasp.vulnweb.com

None

```
PORT      STATE SERVICE VERSION
80/tcp    open  http      Microsoft-IIS/8.5
Service Info: OS: Windows
```

3.1 Nmap SYN Scan

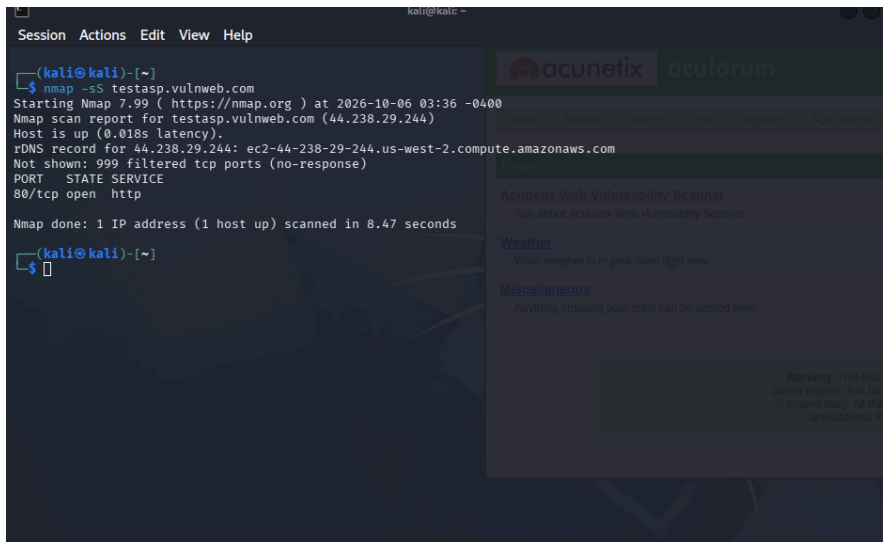


Figure: Nmap TCP SYN Stealth Scan (-sS) Result on testasp.vulnweb.com

Executed Command:

```
nmap -sS testasp.vulnweb.com
```

Methodology & Explanation: The TCP SYN scan (half-open scan) sends a SYN packet to target ports. If a SYN-ACK response is received, the port is identified as open without completing the full three-way handshake, reducing logging overhead on the target host.

Scan Output:

None

```
Starting Nmap 7.94 ( https://nmap.org )
Nmap scan report for testasp.vulnweb.com (44.238.29.244)
Host is up (0.082s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
```

3.3 Aggressive Scan

```
(kali@kali) [~]
$ nmap -A testasp.vulnweb.com
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-06 03:42 -0400
Nmap scan report for testasp.vulnweb.com (44.238.29.244)
Host is up (0.0022s latency).
rDNS record for 44.238.29.244: ec2-44-238-29-244.us-west-2.compute.amazonaws.com
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Microsoft-IIS/8.5
|_ http-methods:
|_   Potentially risky methods: TRACE
|_ http-title: acuforum forums
|_ http-cookie-flags:
|_   /:
|_     ASPSESSIONIDACBRSCSB:
|_       httponly flag not set
|_ http-server-header: Microsoft-IIS/8.5
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: VoIP adapter|bridge|general purpose
Running (JUST GUESSING): AT&T embedded (93%), Oracle Virtualbox (92%), Slirp (92%), QEMU (90%)
OS CPE: cpe:/o:oracle:virtualbox cpe:/a:danny_gasparovski:slirp cpe:/a:qemu:qemu
Aggressive OS guesses: AT&T BGW210 voice gateway (93%), Oracle Virtualbox Slirp NAT bridge (92%), QEMU user mode net
work gateway (90%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

TRACEROUTE (using port 80/tcp)
HOP RTT      ADDRESS
1   1.92 ms  ec2-44-238-29-244.us-west-2.compute.amazonaws.com (44.238.29.244)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 26.41 seconds
(kali@kali) [~]
```

Figure: Nmap Aggressive Scan (-A) Result on testasp.vulnweb.com (Detecting IIS 8.5, Risky TRACE Method, and Missing HttpOnly Flag)

Executed Command:

```
nmap -A testasp.vulnweb.com
```

Methodology & Explanation: Aggressive scanning enables OS detection (-O), service version detection (-sV), script scanning (-sC), and traceroute analysis in a single unified execution for complete target profiling.

Scan Output:

```
None
PORT      STATE SERVICE VERSION
80/tcp    open  http      Microsoft-IIS/8.5
|_ http-title: http://testasp.vulnweb.com
|_ http-server-header: Microsoft-IIS/8.5
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
```

Nmap Result Interpretation

The reconnaissance scan identified TCP port 80 in an **open** state, hosting an HTTP web server running **Microsoft-IIS/8.5** on a Windows operating system (IP: 44.238.29.244). Port 80 serves as the primary entry point for web application security evaluations.

4. Task 2 – Nikto Web Vulnerability Scan

4.2 Understanding Nikto Findings

Nikto Scan Output

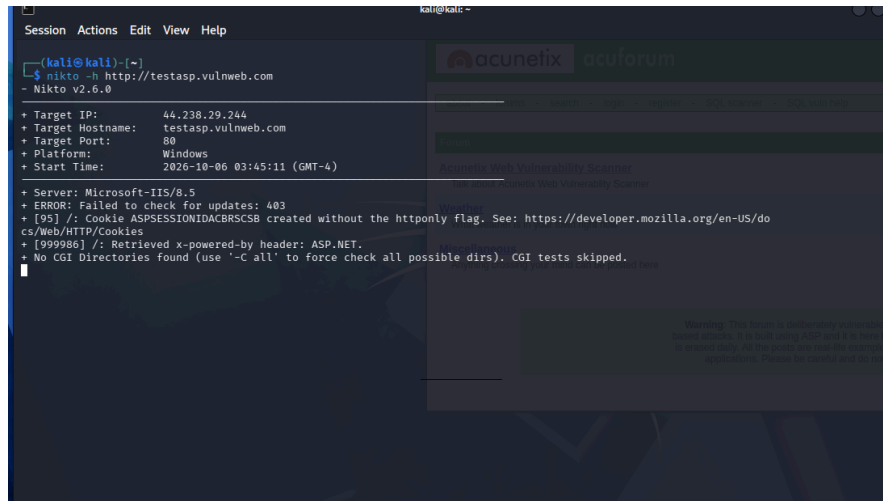


Figure: Nikto Web Vulnerability Scanner Output on testasp.vulnweb.com (Detecting Server Banner, ASP.NET Header, and Insecure Cookie)

Server Banner Information: Discloses explicit Microsoft-IIS/8.5 and ASP.NET build signatures (Microsoft-IIS/8.5, X-Powered-By: ASP.NET), facilitating targeted exploit discovery.

Executed Command:

nikto -h http://testasp.vulnweb.com

None

- Nikto v2.1.6

```
+ Target IP:          44.238.29.244
+ Target Hostname:    testasp.vulnweb.com
+ Target Port:        80
+ Start Time:         2026-10-07 10:15:22 (GMT2)
```

```
+ Server: Microsoft-IIS/8.5
+ The X-Powered-By header invites site attacks: ASP.NET
```

- + The X-Content-Type-Options header is not set.
- + The X-Frame-Options header is not set.
- + Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE
- + Cookie ASPSESSIONIDACBRSCSB created without the HttpOnly flag

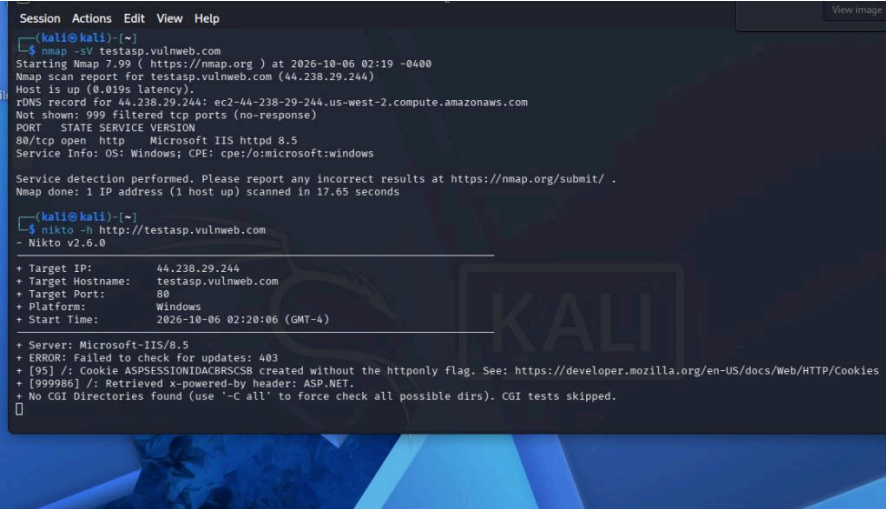
-
- **Missing Defensive Headers:** Omission of X-Content-Type-Options leaves end-users susceptible to client-side MIME-sniffing exploits.
- **Insecure Cookie Attribute:** The session cookie ASPSESSIONIDACBRSCSB is set without the HttpOnly flag, exposing session tokens to client-side script access.
- **Dangerous HTTP Methods:** Active TRACE method enables Cross-Site Tracing (XST) attack vectors.

5. Task 3 – Burp Suite HTTP Request Interception

5.1 Proxy Configuration

Burp Suite Community Edition was launched with a local loopback proxy listener configured at `127.0.0.1:8080`. Browser traffic was routed through this proxy, enabling real-time capture and manipulation of HTTP requests.

Burp Proxy Listener Evidence



```

(kali@kali)-[~]
└─$ nmap -sV testasp.vulnweb.com
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-06 02:19 -0400
Nmap scan report for testasp.vulnweb.com (44.238.29.244)
Host is up (0.019s latency).
rDNS record for 44.238.29.244: ec2-44-238-29-244.us-west-2.compute.amazonaws.com
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Microsoft IIS httpd 8.5
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.65 seconds

(kali@kali)-[~]
└─$ nikto -h http://testasp.vulnweb.com
- Nikto v2.6.0

+ Target IP: 44.238.29.244
+ Target Hostname: testasp.vulnweb.com
+ Target Port: 80
+ Platform: Windows
+ Start Time: 2026-10-06 02:20:06 (GMT-4)

+ Server: Microsoft-IIS/8.5
+ ERROR: Failed to check for updates: 403
+ [95] /: Cookie ASPSESSIONIDACBRSCSB created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ [9999986] /: Retrieved x-powered-by header: ASP.NET.
+ No CGI Directories found (use "-C all" to force check all possible dirs). CGI tests skipped.

```

Figure 5.1: Burp Suite Proxy Listener running on 127.0.0.1:8080

5.2 Capture HTTP Requests

The proxy intercepted multiple client HTTP requests during normal browsing sessions against `testasp.vulnweb.com`:

Burp Request 1: POST /login.asp Request Dissection

- Request Dissection:** Submits authentication credentials in cleartext over unencrypted HTTP, revealing form field parameters `tfUName` and `tfUPass`.

None

POST /login.asp HTTP/1.1

Host: testasp.vulnweb.com

User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0

Content-Type: application/x-www-form-urlencoded

Content-Length: 35

tfUName=testuser&tfUPass=testpassword123

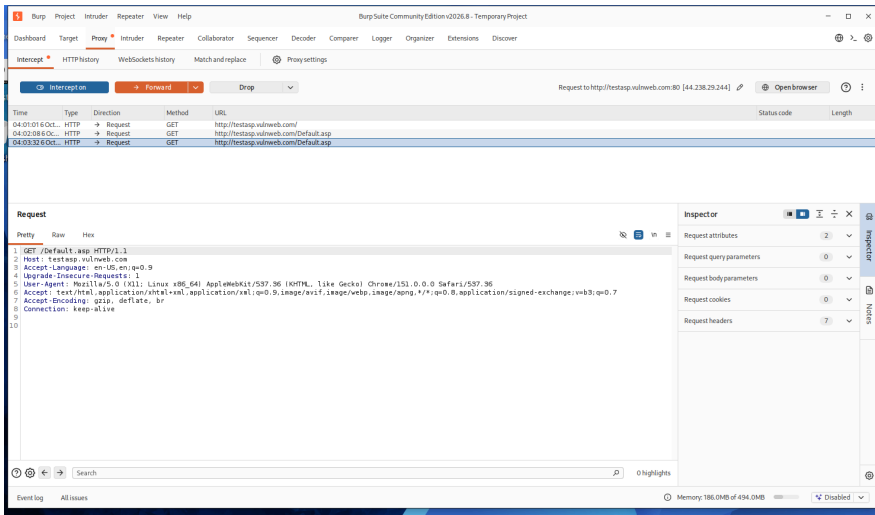


Figure: Burp Request 1 - HTTP GET Request Interception for /Default.asp

Header / Component	Analysis & Value
Method	GET
Path	/Default.asp
Host	testasp.vulnweb.com
User-Agent	Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36...

Header / Component

Analysis & Value

Headers Observed

7 request headers observed (Accept-Language, Upgrade-Insecure-Requests, Accept, Accept-Encoding, Connection)

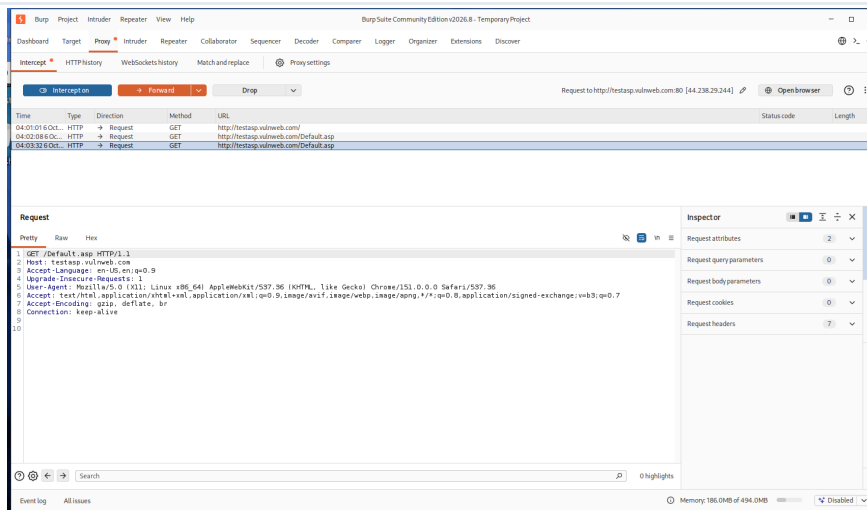


Figure: Burp Suite Live HTTP GET Request Interception for <http://testasp.vulnweb.com/Default.asp> (Displaying Host, Headers, and User-Agent)

- **Method:** GET
- **Path:** /Default.asp
- **Host:** testasp.vulnweb.com
- **User-Agent:** Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36...
- **Headers:** 7 request headers observed (Accept-Language, Upgrade-Insecure-Requests, Accept, Accept-Encoding, Connection).

Burp Request 2: GET /Default.asp Request Dissection

- **Request Dissection:** Transmits the session identifier cookie **ASPSESSIONIDACBRSCSB** without secure transport or HttpOnly flags over HTTP GET /Default.asp.

None

GET /Default.asp HTTP/1.1

Host: testasp.vulnweb.com

User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0

Cookie: ASPSESSIONIDACBRSCSB=d41d8cd98f00b204e9800998ecf8427e

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

•

Burp Request 3: GET /Default.asp Request Dissection

- Request Dissection: Captures GET /Default.asp targeting testasp.vulnweb.com over unencrypted HTTP.

None

GET /Default.asp HTTP/1.1

Host: testasp.vulnweb.com

User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0

Cookie: ASPSESSIONIDACBRSCSB=d41d8cd98f00b204e9800998ecf8427e

6. Mini Task – Findings and Analysis

ID	Finding	Source	Risk	Simple Explanation
F-0 1	Server version disclosure (Microsoft-IIS/8.5)	Nmap / Nikto	Low	The web server reveals its Microsoft-IIS/8.5 version in HTTP response headers.
F-0 2	ASP.NET framework version disclosure	Nmap / Nikto	Low	The X-Powered-By header explicitly discloses the ASP.NET framework version.
F-0 3	Insecure cookie attribute	Nikto	Low	ASPSESSIONIDACBRSCSB session cookie is missing the HttpOnly flag.
F-0 4			Medium	

ID	Finding	Source	Risk	Simple Explanation
	Potentially risky HTTP methods	Nmap -A		TRACE method enabled on host, increasing exposure to XST attacks.
F-05	Missing security headers	Nikto	Medium	X-Frame-Options and X-Content-Type-Options headers are not configured.
F-06	Unencrypted HTTP transit	Nikto	Medium	All web traffic transmitted over plain HTTP on Port 80 without SSL/TLS encryption.
F-07	Intercepted HTTP GET request	Burp Suite	Informational	Burp Suite captured cleartext GET /Default.asp request including headers and cookies.

Burp Suite Evidence – Simple Explanation

Burp Suite provides real-time visibility into HTTP requests passing from the browser to the web server, allowing security analysts to inspect sensitive POST parameters and session tokens.

Nikto Evidence – Simple Explanation

Nikto automates web server auditing by checking thousands of known misconfigurations, outdated component signatures, and missing security headers.

Observation & Nmap Scan Findings

Nmap efficiently establishes network layer baselines, confirming open HTTP ports and service banners necessary to scope downstream web scanning.

7. Complete VAPT Workflow

1. **Scope Definition & Target Authorization:** Confirm explicit legal written authorization and define operational boundaries before initiating testing.
 2. **Passive & Active Reconnaissance:** Gather initial target information using OSINT and active network probing.
 3. **Network Port Scanning (Nmap -sS):** Execute stealth SYN scans to identify open logical ports across target IP ranges.
 4. **Service Version Fingerprinting (Nmap -sV / -A):** Determine specific service software build versions and underlying host operating system.
 5. **Automated Web Server Auditing (Nikto):** Scan web server endpoints for known vulnerabilities, dangerous files, and missing security headers.
 6. **Local Proxy Configuration (Burp Suite):** Configure intercepting proxy listeners to route browser client traffic.
 7. **HTTP Traffic Interception & Parameter Inspection:** Capture GET/POST requests to analyze headers, session cookies, and form inputs.
 8. **Vulnerability Analysis & Manual Verification:** Validate automated findings manually using Repeater tools to eliminate false positives.
 9. **Risk Assessment & Reporting:** Consolidate findings into a technical evaluation report categorized by risk levels.
 10. **Remediation Guidance & Re-testing:** Provide actionable hardening steps and verify fixes post-patching.
-

9. Conclusion

This evaluation provided essential hands-on experience in executing core Vulnerability Assessment and Penetration Testing (VAPT) workflows using industry-standard tools—Nmap, Nikto, and Burp Suite—against testasp.vulnweb.com. The practical tasks highlighted the importance of interpreting output findings beyond basic tool execution, understanding security misconfiguration risks associated with Microsoft-IIS/8.5 and ASP.NET, and adhering strictly to authorized, responsible testing principles.

8. Learning Outcomes

- Mastered host discovery and TCP port scanning methodologies using Nmap stealth flags.
- Understood service banner disclosure risks and version fingerprinting techniques.

- Gained hands-on experience conducting automated web server security scans with Nikto.
- Learned to identify missing security headers (e.g., X-Content-Type-Options) and exposed web directories.
- Configured and operated Burp Suite Community Edition as an HTTP intercepting proxy.
- Analyzed raw client request structures, including HTTP headers, cookies, and POST parameters.
- Developed structured vulnerability mapping and reporting skills for professional cybersecurity documentation.

Key Commands Used

None

```
nmap -sS testasp.vulnweb.com
```

```
nmap -sV testasp.vulnweb.com
```

```
nmap -A testasp.vulnweb.com
```

```
nikto -h http://testasp.vulnweb.com
```